# Information Security Terminology

Information Security has several important terms that help understand how attacks, threats, and protections work. Below are the **key terms** with clear meanings and examples:

## 1. Asset

- **Definition:** Anything valuable to an organization or person that needs protection.
- **Examples:**
  - Hardware (computers, routers)
  - Software (applications, databases)
  - Data (customer records, passwords)
  - People (employees with special knowledge)

## 2. Threat

- **Definition:** A **potential danger** that can exploit a weakness and harm an asset.
- **Example:**
  - A hacker trying to steal data.
  - A flood damaging data centres.

## 3. Vulnerability

- **Definition:** A **weakness or flaw** in a system that allows a threat to cause harm.
- **Examples:**
  - Weak passwords
  - Unpatched software
  - Open network ports

## 4. Risk

- **Definition:** The **chance or probability** that a threat will exploit a vulnerability and cause loss.

- **Formula:**
  `Risk = Threat × Vulnerability × Impact`

- **Example:** If a system has weak passwords (vulnerability) and a hacker (threat) tries to access it, the **risk** of data theft is high.

## 5. Attack

- **Definition:** The **actual action** of exploiting a vulnerability to harm a system.
- **Examples:**
  - Sending malware to infect systems.
  - SQL injection to access the database.

## 6. Security Policy

- **Definition:** A **set of rules and guidelines** that defines how information and systems must be protected.
- **Examples:**
  - Password policy (strong password rules)
  - Access control policy
  - Data retention policy

## 7. Security Mechanism

- **Definition:** A **technical method** used to achieve security goals (confidentiality, integrity, etc.).
- **Examples:**
  - Encryption
  - Authentication systems
  - Firewalls

## 8. Encryption

- **Definition:** Converting readable data (plaintext) into unreadable form (ciphertext) to protect it.

- **Example:** Using AES or RSA algorithms.

## 9. Decryption

- **Definition:** Converting encrypted data back into readable form using a decryption key.

## 10. Firewall

- **Definition:** A **network security device** that filters incoming and outgoing traffic based on rules.
- **Example:** Blocks unauthorized access to a private network.

## 11. Intrusion Detection System (IDS)

- **Definition:** Monitors system/network activities and **detects suspicious behaviour** or attacks.

## 12. Intrusion Prevention System (IPS)

- **Definition:** Like IDS but also **blocks** detected attacks automatically.

## 13. Phishing

- **Definition:** A **fake message or email** that tricks users into giving personal information.
- **Example:** "Your account will be blocked — click this link."

## 14. Least Privilege Principle

- **Definition:** Users should have **only the minimum access rights** needed to perform their tasks.
- **Example:** A cashier cannot change the system settings.

## 15. Insider Threat

- **Definition:** Security threat caused by employees or trusted individuals inside an organization.
- **Example:** Employee leaking confidential files.

## 16. Backup

- **Definition:** Copy of data stored separately to **recover information** in case of loss or attack.
- **Example:** Cloud backup or external hard drive backup.